

ACTIVIDAD 01

Análisis y planificación del pentest

Escenario: Aurora Market

Nombre completo	Mariel Lizeth Blandon Chandler
Fecha	4/09/2026
Curso / grupo	Hacker Woman Council – Ethical Hacking

1. Objetivo del pentest

Definí tres objetivos concretos que tendría la evaluación de seguridad de Aurora Market.

GUÍA Pensá qué querés lograr con el pentest y cómo cada objetivo ayudaría a proteger el negocio, sus sistemas o la información de sus clientes.

OBJETIVO 1

Identificar vulnerabilidades y determinar qué tan expuestas están sus aplicaciones ante posibles ataques cibernéticos

OBJETIVO 2

Evaluar los riesgos encontrados y determinar que podría afectar a la empresarial y a sus clientes

OBJETIVO 3

Elaborar un informe detallado de todo lo encontrado dentro de los alcances y proponer medidas que pueden utilizar para mejorar la seguridad de la plataforma web

2. Alcance

Identificá claramente qué se evaluará y qué quedará fuera del alcance.

GUÍA Sé específica: podés indicar sistemas, aplicaciones, redes, datos, horarios, sedes o equipos. Evitá expresiones demasiado generales.

SÍ SE EVALUARÁ — Sistemas o elementos incluidos en el alcance

- Se evaluará la aplicación web autorizada de Aurora Market, tanto desde la parte pública como mediante la cuenta de usuario sin privilegios proporcionada. También se analizarán los mecanismos de autenticación, autorización, registro, compras, pagos y los flujos de datos accesibles desde la aplicación.

FUERA DEL ALCANCE — Elementos que no serán evaluados

- Redes sociales de la empresa.
- Los equipos personales de sus empleados.
- Sus cuentas de correo.
- Ningún otro sistema que no formen parte del alcance acordado.

3. Autorización y condiciones

Explicá qué permisos y condiciones deben definirse antes de comenzar las pruebas.

GUÍA Incluí la autorización formal y las reglas que protegen a Aurora Market durante la evaluación: responsables, horarios, límites, manejo de datos y comunicación de incidentes.

PERMISOS REQUERIDOS

- Evaluar solamente la aplicación web autorizada.
- Contar con una autorización formal y por escrito para evaluar la aplicación web
- Realizar las pruebas únicamente sobre los activos definidos en el alcance.
- Colaborar en confianza, transparencia y comunicación.

CONDICIONES ACORDADAS

- No está permitido realizar acciones que puedan interrumpir deliberadamente el funcionamiento de la plataforma o afectar la información real de los clientes.
- Realizar las pruebas durante horarios de menor actividad.
- No atacar redes sociales, equipos, correos proveedores ni otros sistemas fuera del alcance.

4. Tipo de pentest

Determiná si el escenario corresponde a un pentest Black-box, Gray-box o White-box y justificá tu elección.

GUÍA Marcá una opción. Después explicá qué información tendrá el equipo evaluador y por qué ese enfoque es apropiado para Aurora Market.

☐ BLACK-BOX	☒ GRAY-BOX	☐ WHITE-BOX
Sin información previa o con conocimiento mínimo.	Con información y accesos limitados.	Con acceso amplio a información y configuración.

JUSTIFICACIÓN DE LA ELECCIÓN

Utilizaría un pentest gray-box, ya que la empresa no nos dará información de la infraestructura y únicamente trabajaremos con una cuenta de usuario sin privilegios, La empresa quiere conocer atreves de la evaluación que podría descubrir un atacante con la información que un usuario legitimo tenga disponible. Por lo cual este tipo de pentest se acopla muy bien.

5. Planificación

Establecé qué debe hacerse y definirse antes de comenzar la parte técnica del pentest.

GUÍA Resumí aquí las decisiones principales de los apartados anteriores y agregá metodología, información previa, recursos y fechas.

OBJETIVOS — ¿Qué se espera comprobar o lograr?

Conocer que están expuesta esta la empresa, que riesgos existen y proponer medidas que mejoren la seguridad de la aplicación web

ALCANCE — ¿Qué activos se evaluarán y cuáles no?

Se evaluará solamente la aplicación web, no se atacarán redes sociales, equipos, correos proveedores ni otros sistemas.

PERMISOS Y CONDICIONES — ¿Qué autorizaciones, límites y reglas aplican?

Se evaluará únicamente la aplicación web, no está permitido realizar acciones que puedan interrumpir deliberadamente el funcionamiento de la plataforma o afectar la información real de los clientes, no se realizarán las pruebas durante horarios de menor actividad, no se atacarán redes sociales, equipos, correos proveedores ni otros sistemas fuera del alcance.

METODOLOGÍA A UTILIZAR — ¿Qué guía o marco seguirá el equipo?

El equipo seguirá la guía OWASP Web Security Testing Guide (WSTG)

RECOPIACIÓN DE INFORMACIÓN PREVIA — ¿Qué datos se necesitan antes de iniciar?

Se recopilará información sobre el dominio y las tecnologías visibles de la aplicación. Además, se solicitarán la URL autorizada, las credenciales de la cuenta de prueba, los horarios permitidos, los datos de contacto del equipo técnico y la confirmación de los sistemas que están dentro y fuera del alcance.

RECURSOS NECESARIOS — ¿Qué personas, herramientas, equipos o accesos se requieren?

Se necesitarán computadoras de prueba, acceso a la aplicación y a la cuenta autorizada, herramientas de análisis web, un navegador con proxy de pruebas, herramientas de reconocimiento pasivo y la colaboración del equipo técnico de Aurora Market.

PROGRAMACIÓN DEL PENTEST — ¿Cuándo se realizará cada actividad y cuánto durará?

El pentest tendrá una duración aproximada de una semana. Las pruebas activas se realizarán únicamente durante los horarios de menor actividad acordados con Aurora Market, distribuyendo el tiempo entre reconocimiento, análisis, validación controlada y elaboración del informe.

6. Fases del pentest

Explicá cómo aplicarías cada fase al caso de Aurora Market y qué se realizaría en ella.

GUÍA Describí acciones concretas para el escenario. Mantené las pruebas dentro del alcance y las condiciones autorizadas.

1. RECONOCIMIENTO — ¿Qué información se recopilará antes de probar los sistemas?

Se recopilará información pública relacionada con la aplicación web, como el dominio, subdominios autorizados, tecnologías utilizadas y servicios visibles. También se revisará la información suministrada por Aurora Market.

2. ANÁLISIS DE VULNERABILIDADES — ¿Cómo se identificarán y validarán posibles debilidades?

Se analizará la aplicación web utilizando herramientas automatizadas y pruebas manuales basadas en OWASP WSTG. Se revisarán posibles debilidades en el registro de usuarios, autenticación, autorización, manejo de sesiones, validación de entradas, proceso de compra y protección de los datos. Los resultados encontrados se validarán manualmente mediante pruebas controladas para descartar falsos positivos, sin afectar el servicio ni la información real de los clientes.

3. EXPLOTACIÓN — ¿Cómo se comprobará de forma controlada si una vulnerabilidad puede aprovecharse?

Las vulnerabilidades confirmadas se comprobarán mediante pruebas controladas y de impacto mínimo. Solo se demostrará lo necesario para comprobar que la vulnerabilidad puede ser aprovechada, sin alterar datos reales, interrumpir la plataforma ni acceder a sistemas fuera del alcance.

4. POST-EXPLOTACIÓN — ¿Qué impacto y alcance se analizarán después de obtener acceso?

Después de obtener acceso, se evaluará de manera limitada qué acciones podría realizar un atacante, si sería posible aumentar privilegios o acceder a funciones e información no autorizadas. No se modificarán ni extraerán datos reales, no se instalarán mecanismos de persistencia y no se intentará acceder a otros sistemas fuera del alcance. Se conservará la evidencia necesaria y se informará al equipo técnico.

5. INFORME — ¿Cómo se documentarán hallazgos, evidencias, riesgos y recomendaciones?

Los hallazgos se documentarán indicando la vulnerabilidad encontrada, la evidencia obtenida, el activo afectado, el nivel de riesgo y su posible impacto en Aurora Market y sus clientes. También se explicarán los pasos utilizados para comprobarla y se incluirán recomendaciones para corregirla. El informe tendrá un resumen ejecutivo para la empresa y una sección técnica para el equipo encargado de solucionar los problemas.

7. Investigación

Consultá al menos una metodología de pentesting y explicá por qué podría utilizarse en este proyecto.

GUÍA Podés investigar, por ejemplo, PTES, NIST SP 800-115, OWASP Web Security Testing Guide u otra metodología reconocida. Citá la fuente consultada.

Metodología elegida:

RESUMEN DE LA METODOLOGÍA — ¿En qué consiste y cuáles son sus etapas principales?

OWASP Web Security Testing Guide es una guía para planificar y ejecutar pruebas de seguridad en aplicaciones web. Consiste en analizar de forma organizada diferentes componentes de la aplicación para identificar y comprobar vulnerabilidades. Incluye pruebas de recopilación de información, configuración, gestión de identidades, autenticación, autorización, sesiones, validación de entradas, manejo de errores, criptografía, lógica de negocio y seguridad del lado del cliente. Los hallazgos deben validarse y documentarse junto con su impacto y las recomendaciones correspondientes.

¿POR QUÉ SERÍA ÚTIL PARA EL PROYECTO DE AURORA MARKET?

Esta metodología sería útil porque el principal activo que Aurora Market necesita evaluar es su aplicación web. La guía permite revisar funciones importantes del caso, como el registro de usuarios, el inicio de sesión, los permisos, las sesiones, el proceso de compra, los pagos y el manejo de información de los clientes. Además, proporciona una estructura ordenada para identificar, validar y documentar vulnerabilidades sin realizar pruebas fuera del alcance autorizado.

Fuente(s) consultada(s):

OWASP Foundation. OWASP Web Security Testing Guide, versión 4.2. <https://owasp.org/www-project-web-security-testing-guide/v42/>